

PRE-LAUNCH · LEGAL & PATENT PREPARATION

Legal & Patent Review Brief

Customer Data Inventory · DPDP Compliance · Patent Surface

Privileged & Confidential. Prepared for legal counsel in connection with pre-launch DPDP Act 2023 review and patent filing assessment. Contains technical descriptions of proprietary systems.

A complete, sourced inventory of every place customer personal data is collected, stored, processed and shared in the Wearify codebase — with identified compliance gaps under the Digital Personal Data Protection Act 2023 and a list of technical aspects that may be patentable.

CONTENTS

- | | | | |
|----------|--|-----------|--|
| 1 | Executive Summary | 9 | Cross-Border Data Flows (DPDP §16) |
| 2 | Personal Data Inventory — What We Collect | 10 | Security & Access Controls |
| 3 | Where Data Is Collected (UI Surfaces) | 11 | Retention & Deletion (DPDP §8(7), §12) |
| 4 | Where Data Is Stored (Database & Files) | 12 | Audit Logging |
| 5 | Third Parties That Receive Customer Data | 13 | KYC Data — Stores & Tailors |
| 6 | Biometric & Sensitive Data — the Body Scan | 14 | Identified Compliance Gaps |
| 7 | Children's Data (DPDP §9) | 15 | Patent-Relevant Novel Aspects |
| 8 | Consent Mechanism (DPDP §6) | 16 | Questions for Counsel |

PREPARED MAY 2026 | SCOPE: ENTIRE CODEBASE | APPLICABLE LAW: DPDP ACT 2023 (INDIA)

1 Executive Summary

Wearify is an AI virtual try-on platform for Indian saree retailers. The product collects, stores and processes a meaningful amount of personal data — including **biometric-adjacent body-scan photographs and body measurements** — and shares portions of that data with three United-States-based sub-processors (RunPod, SendGrid, Twilio). This brief inventories every such touchpoint, identifies compliance gaps under the **Digital Personal Data Protection Act 2023**, and flags technical inventions for patent assessment.

HEADLINE FINDINGS — FOR IMMEDIATE COUNSEL ATTENTION

1. **No "delete my account" flow exists** for customers. The Right to Erasure (DPDP §12) is not implemented.
2. **Consent is set to TRUE by default** on customer creation (all four DPDP-style flags), not captured as explicit opt-in.
3. **Age gate is 13+, not 18+**. DPDP defines a "child" as a person under 18 and requires *verifiable parental consent* (§9). No parental-consent mechanism exists.
4. **The audit-log table is defined but never written to** — no record of data access, KYC uploads, consent changes, or admin actions.
5. **Customer body-scan images and saree images are sent in base64 to RunPod (US)** for AI try-on. No Data Processing Agreement is visible in code; cross-border transfer mechanism (DPDP §16) must be verified.

POSITIVE FINDINGS

Passwords and staff PINs are hashed with **PBKDF2-SHA256 (100,000 iterations, per-user 16-byte salt)**, with constant-time comparison. Rate-limit tables exist for password, PIN, trial-code and pairing-code attempts. File uploads are validated server-side (size + MIME). Cross-store data isolation is enforced via device tokens and saree-ownership checks. Kiosk pairing uses ephemeral 6-digit codes plus 32-byte (256-bit) long-lived device tokens.

PATENT SURFACE — FOR PATENT COUNSEL

Five technical areas warrant patentability review: (a) the AI try-on pipeline — Qwen-Image-Edit 2511 + Object-Adder LoRA + flat-lay garment selection; (b) the kiosk pairing protocol — ephemeral codes + long-lived bearer tokens with per-store rate-limiting; (c) the trial-room access-code handoff between tablet and mirror; (d) body-scan cache invalidation by file-identity rather than timestamp; (e) the sequential WASM background-removal queue for resource-bounded edge devices. See Section 15 for detail.

2 Personal Data Inventory — What We Collect

Every personal-data field on the customer record, grouped by sensitivity. Source: `convex/schema.ts`, lines 214–280. Sensitive rows are tinted.

CATEGORY	FIELD	TYPE	NOTES / DPDP RELEVANCE
Identity	phone	string (indexed)	Primary identifier; required.
Identity	name	string	Required at registration.
Identity	email	string (optional)	Used for campaigns; sent to SendGrid.
Identity	dateOfBirth	ISO date (optional)	Used for 13+ age check. <i>Should be 18+ per DPDP §9.</i>
Identity	gender	string	male / female / other / prefer_not_to_say.
Identity	city	string	Required for profile completion.
Body data	heightCm	number 50-250	Body metric.
Body data	bust, waist, shoulder, armLength, backLength, neckDepthFront, neckDepthBack, sleeve, neck	strings	Detailed body measurements. Shared with tailor partners when an order is placed (see Section 5).
Biometric / photo	photoFileId	storage ref (4 MB cap, image/*)	Profile photo (face).
Biometric / photo	bodyScanFileId	storage ref (10 MB cap, image/*)	Full-body photograph of the customer. Required for AI try-on. Sent (base64) to RunPod for processing.
Biometric / photo	lastBodyScan	timestamp	When the body scan was captured.
Authentication	passwordHash + passwordSalt	PBKDF2-SHA256 hex + 16-byte salt	Never returned to clients.
Behavioural	loyaltyPoints, loyaltyTier	number / string	Loyalty program data.
Behavioural	preferredOccasions, preferredFabrics, preferredColors, budgetRange, upcomingOccasion(+Date), notifyTime	strings / arrays	Personalisation preferences.
Behavioural	language	string	One of 9 Indian languages (EN/HI/MR/KN/TA/TE/BN/GU/ML).
Consent	consentHistory, consentMessages, consentAiPersonal, consentPhotos, consentGrantedDate	boolean × 4 + ISO date	DPDP-style consent flags. Default TRUE on creation — see Section 8.
Notification prefs	notifTryOn, notifThankYou, notifFestivals, notifNewArrivals, notifBirthday, notifReengagement	booleans	Per-channel notification opt-ins.

PII-bearing fields also appear on these adjacent tables: `users`, `userSessions`, `customerStoreLinks`, `visitHistory`, `loyaltyTransactions`, `customerReferrals`, `sessions`, `looks`, `wardrobe`, `kioskCart`, `orders`, `feedback`, `campaignSends`, `tailorReferrals`, `tailorOrders`, `shortlist`, `trialRoom`, `wishlist`. Where these tables carry customer phone or measurements, they are flagged in the corresponding sections below.

3 Where Customer Data Is Collected

SURFACE	FILE	DATA CAPTURED	MUTATION CALLED
Customer PWA — registration	app/c/register/page.tsx	Phone, OTP, full name, DOB, gender, height, city, email, profile photo	customers.completeProfile
Customer PWA — login	app/c/login/page.tsx	Phone, OTP / password	phoneAuth.loginWithOtp / loginWithPassword
Customer PWA — profile edit	app/c/me/profile/page.tsx	Name, gender, height, city, email, photo	customers.updateProfile
Customer PWA — preferences	app/c/me/preferences/page.tsx	Occasions, fabrics, colours, budget, upcoming occasion, notify time	customers.updatePreferences
Tablet — register new customer	app/tablet/register/page.tsx	Phone, name, DOB, language	customers.ensureByPhone
Kiosk — new-customer capture	app/kiosk/page.tsx (newCustomer screen)	Name, DOB (13+ gate enforced UI-side only)	customers.ensureByPhone
Kiosk — consent	app/kiosk/screens/ConsentScreen.tsx	4 consent flags + granted date (single "Allow" toggle)	customers.updateConsent
Kiosk — body scan capture	app/kiosk/screens/BodyScanScreen.tsx	Full-body photograph from kiosk camera, JPEG quality 0.9	customers.recordBodyScan
Kiosk — feedback	app/kiosk/screens/FeedbackScreen.tsx	Rating 1-5, quick-tag chips, free-text comment	customers.submitFeedback
Kiosk — data-save choice	app/kiosk/screens/DataSaveScreen.tsx	Save / Delete decision for the session's looks	sessionOps.addToWardrobe (if Save)

NOTE

Several surfaces collect identical fields (name, DOB, etc.). The validation logic lives in `lib/profileHelpers.ts` but is enforced **only at the UI layer**. Server mutations (e.g. `customers.ensureByPhone`) accept the data without re-validating age — a non-PWA path could create an under-13 record. See Sections 7 and 14.

4 Where Customer Data Is Stored

All structured data sits in the Convex database. Files (photos, scans, documents) sit in Convex File Storage. The Convex deployment is hosted in **EU-West-1 (Ireland)** — see Section 9.

► Tables holding customer data

TABLE	WHAT IT HOLDS	PII PRESENT
customers	The primary customer record (see Section 2)	All — incl. biometric
users	Auth record (phone + password) for customer / store-owner / tailor / staff	Phone, name, password hash
userSessions	Per-device session tokens	Token + userId reference
customerStoreLinks	Customer ↔ store many-to-many; CLV, visits, segment	Customer ID, behavioural data per store
visitHistory	Per-customer visit audit trail	Customer ID, store, date, sarees tried, purchase flag
loyaltyTransactions	Points earn / redeem records	Customer ID, points, reason
customerReferrals	Friend-referral records	Referrer phone, referred friend's name and phone
sessions	Mirror / tablet session context	Customer ID, phone, ratings, notes
looks	AI try-on results	Customer ID, personFileId (body-scan snapshot) , imageFileId (rendered try-on)
wardrobe	Customer-saved looks per session	Customer ID + lookId
kioskCart	Per-(customer, store) shopping cart	Customer ID, sarees, quantities
orders	Purchase orders	Customer ID, phone, items, totals
feedback	Session feedback	Customer ID, phone, rating, free-text comment
campaignSends	Per-recipient dispatch log (email/SMS/WhatsApp)	Recipient (email or phone) in plaintext
shortlist	Staff-curated sarees per session	Customer ID
trialRoom	Tablet → Mirror 6-digit access codes (15-min TTL)	Customer ID, phone, code
wishlist	Customer-saved items	Customer ID + saree IDs
tailorReferrals	Customer leads referred to tailor partners	Customer name + phone shared with tailor
tailorOrders	Blouse-stitching orders	Customer name, phone AND all body measurements copied to the order

► File-storage references

FIELD	WHAT IT HOLDS	SIZE / TYPE CAP
customers.photoFileId	Profile photo	4 MB, image/*
customers.bodyScanFileId	Body-scan photograph	10 MB, image/*
looks.imageFileId	AI-rendered try-on PNG	10 MB
looks.imageNoBgFileId	Background-removed cutout	5 MB, image/png
looks.personFileId	Snapshot of body-scan used for the render	(same as bodyScan)
stores.*FileId (×7)	Store KYC: Aadhaar, PAN, GST cert, shop license, store photos	10 MB, image/* or PDF
tailors.*FileId (×3)	Tailor KYC: Aadhaar, PAN, address proof	10 MB, image/* or PDF

5 Third Parties That Receive Customer Data

Three external services receive customer data today. Each is a **data processor / sub-processor** under DPDP Act §2(k) and requires a data-processing agreement.

► 5.1 RunPod — AI try-on GPU

Service	RunPod Serverless GPU (api.runpod.ai)
Residency	United States (configured endpoint region; transnational under DPDP §16)
What is sent	The customer's body-scan photograph (base64) and the saree catalog image (base64), in a ComfyUI workflow JSON payload
Customer identifiers sent	None — only the binary images. No name, phone, email or customer ID is transmitted.
Endpoint	POST /v2/{endpointId}/run · GET /v2/{endpointId}/status/{jobId}
Auth	Bearer token (<code>RUNPOD_API_KEY</code> env var, server-side only)
Source	convex/runpod.ts · convex/tryOn.ts

► 5.2 SendGrid — email campaigns

Service	SendGrid Email API (api.sendgrid.com)
Residency	United States (transnational under DPDP §16)
What is sent	Customer email address (plaintext) , customer name (in template variables), subject, message body
Trigger	Store campaign dispatch (filtered by segment of <code>customerStoreLinks</code>)
Source	convex/campaignOps.ts:210-230 (sendEmail)
Simulation	If <code>SENDGRID_API_KEY</code> not set, send is logged as "simulated" — no real API call.

► 5.3 Twilio — SMS, OTP and WhatsApp

Service	Twilio Messages API (api.twilio.com)
Residency	United States (transnational under DPDP §16)
What is sent	Customer phone number (plaintext) , message body (template-rendered)
Channels	SMS, WhatsApp (via Advanced Messaging)
Source	convex/campaignOps.ts:232-254 (sendTwilio)
Simulation	If credentials not set, send is "simulated".

► 5.4 Tailor partners — not a SaaS, but a human recipient

Recipient	Independent stitching partners ("tailors") with accounts in the platform
What is shared	Customer name, phone, body measurements — copied into <code>tailorReferrals</code> and <code>tailorOrders</code> rows visible to the tailor
Consent capture	<i>None at present.</i> No explicit "share with tailor" consent step. The data flows through the order pipeline.
Source	convex/tailorOps.ts (createReferral, createOrder)

ACTION FOR COUNSEL

Confirm that **data-processing agreements** (DPAs) are in place with Convex, RunPod, SendGrid and Twilio that meet DPDP §8(8) and §16 requirements. Document the legal basis for the tailor disclosure (likely contractual necessity, but explicit notice / consent at the referral step is safer).

The body-scan photograph is the single most sensitive item of personal data the platform handles. Although DPDP Act 2023 does not yet enumerate "special categories" of data the way GDPR does, full-body photographs combined with detailed body measurements would, under most reasonable interpretations, constitute **highly sensitive personal data** deserving of heightened protection.

► **End-to-end flow of the body-scan image**

STEP	WHAT HAPPENS	SOURCE
1. Capture	Kiosk camera (full-frame video). Pose detection auto-triggers; manual button also available.	app/kiosk/screens/BodyScanScreen.tsx
2. Encode	Canvas-rendered JPEG at quality 0.9	same file, lines ~155-168
3. Upload	POST to Convex storage upload URL (10 MB cap, image/* MIME guard)	lib/useUpload.ts
4. Store	File ID written to <code>customers.bodyScanFileId</code> ; timestamp to <code>customers.lastBodyScan</code>	customers.recordBodyScan
5. Read for try-on	Server fetches blob via <code>ctx.storage.get</code> , base64-encodes	convex/tryOn.ts:603-607
6. Send to RunPod	Base64 image embedded in ComfyUI workflow JSON, POSTed to RunPod US	convex/runpod.ts:399-420
7. Snapshot	The file ID at time-of-render is copied to <code>looks.personFileId</code> for cache coherence	convex/tryOn.ts (<code>_insertQueuedLook</code>)
8. Result stored	RunPod returns rendered image; stored at <code>looks.imageFileId</code>	convex/tryOn.ts (<code>_completeLook</code>)

OPEN EXPOSURE

The body-scan image and AI renders are stored **indefinitely**. There is no automatic deletion, no expiry, and no UI mechanism for the customer to delete a stored body scan. A new scan replaces the file ID on the `customers` row but the underlying storage blob is not necessarily purged. See Sections 11 and 14.

USEFUL NOTE

The body-scan cache (Section 15.4) is invalidated automatically when the customer re-scans, because `looks.personFileId` stops matching the current `customers.bodyScanFileId`. This is a positive design: a re-scan implicitly retires every old AI render for that customer.

DPDP Act 2023, Section 9, requires a Data Fiduciary to **obtain verifiable consent of the parent or lawful guardian** before processing the personal data of a child. The Act defines a "child" as a person who has not completed **eighteen years** of age (§2(f)). DPDP §9(3) further prohibits tracking, behavioural monitoring, and targeted advertising directed at children.

CRITICAL GAP

Wearify currently uses an age gate of **13 years** (`MIN_AGE_YEARS = 13` in `lib/profileHelpers.ts:7`). Customers aged 13–17 are accepted with no parental-consent step. This is GDPR-aligned but **not DPDP-compliant** for customers under 18.

Wearify also **tracks behavioural data** on every customer (visit history, try-on counts, wishlist/wardrobe contents, loyalty tier, preferences) and runs marketing campaigns (email / SMS / WhatsApp) — both of which DPDP §9(3) restricts for children.

► Two further gaps in the age check

WHERE	ISSUE
Server-side enforcement	The 13+ check exists only in the customer PWA UI (<code>app/c/register/page.tsx</code>). The Convex mutation <code>customers.ensureByPhone</code> accepts a DOB without validating it, so the tablet self-service path and any direct API caller can create an under-age customer.
Parental consent	No mechanism exists to capture a parent's or guardian's contact details, to send a verification challenge, or to record verifiable parental consent for an under-18 customer.

RECOMMENDED DISCUSSION

Counsel should advise on (a) raising the gate to 18, or (b) implementing a verifiable-parental-consent flow for 13–17 customers (e.g. parent's phone + OTP, or government-ID verification), and (c) whether marketing campaigns and behavioural profiling can lawfully reach any customer under 18.

DPDP §6 requires consent to be *free, specific, informed, unconditional, unambiguous and given by a clear affirmative action*, and to be limited to the personal data necessary for a specified purpose. Wearify's current consent implementation captures four flags but has structural weaknesses against this standard.

ASPECT	CURRENT IMPLEMENTATION	DPDP §6 ALIGNMENT
Capture surface	Kiosk modal <code>app/kiosk/screens/ConsentScreen.tsx</code> with "Allow" / "Skip" buttons; copy: "We'll use the camera on this mirror to capture your look. Images are saved securely and you can delete them anytime."	Clear affirmative action present (Allow tap). "Skip" affordance is preserved — customer can decline without exiting.
Granularity	Four flags (<code>consentHistory</code> , <code>consentMessages</code> , <code>consentAiPersonal</code> , <code>consentPhotos</code>) are set together by a single "Allow" tap . No per-flag checkbox.	Not aligned with DPDP's <i>specific</i> requirement; treats four distinct purposes as one bundled consent.
Default state	On new customer creation via <code>customers.ensureByPhone</code> , all four flags default to TRUE with today's date , even before any consent UI is shown.	Not aligned — pre-checked / pre-granted consent does not satisfy "clear affirmative action".
Storage	Flags + <code>consentGrantedDate</code> on the <code>customers</code> row.	Adequate as proof of consent, but no version of the notice shown is recorded.
Withdrawal	An <code>updateConsent</code> mutation exists, but there is no customer-facing UI to view or change consent flags after the initial Allow tap.	Not aligned with the right to withdraw consent (DPDP §6(4)–(6)).
Notice / legal docs	<code>LegalDocs</code> table is defined to hold versioned terms / privacy notices, but no code reads it; no admin UI to upload them. The consent screen shows hard-coded copy only.	Not aligned with §5 notice requirements. The required notice (purposes, rights, complaint channel, cross-border details) is not surfaced.

ACTION ITEMS

(1) Remove default-true consent on customer creation. (2) Replace the bundled "Allow" tap with per-purpose checkboxes (or, minimum, separate the "photos / AI personalisation" consent from "marketing messages"). (3) Build a consent-management screen in `/c/me` where the customer can review and withdraw consents. (4) Implement a notice/privacy-policy view fed by the `LegalDocs` table and version-stamp consent records with the policy version accepted.

9 Cross-Border Data Flows — DPDP §16

DPDP §16 permits transfer of personal data outside India unless the Central Government has restricted transfer to a particular country. All Wearify data today is held or processed outside India. The Azure-migration plan (separate document) addresses this by moving everything to Azure's *Central India* region, but as of this brief the current state is:

SERVICE	ROLE	REGION	CUSTOMER DATA SENT
Convex	Primary database + file storage	EU-West-1 (Ireland)	All — every PII field
RunPod	AI try-on GPU	United States	Body-scan image (base64), saree image
SendGrid	Email dispatch	United States	Customer email + name + message body
Twilio	SMS / WhatsApp dispatch	United States	Customer phone + message body
Netlify	Frontend hosting	Global CDN, primary US	Hosting traffic, no PII at rest
Better Auth	Admin sign-in	Runs <i>inside</i> Convex (EU-West-1)	Admin email + password hash only

DISCUSSION FOR COUNSEL

(a) Confirm the customer notice discloses these cross-border transfers, as expected under §5 notice requirements. (b) Confirm DPAs are in place with each sub-processor. (c) The Azure-Central-India migration (separate plan) materially improves this posture by bringing primary data residency in-country; counsel may wish to weigh whether to delay launch until that migration is complete, or proceed with appropriate disclosures.

10 Security & Access Controls

Material security mechanisms present in the codebase today:

CONTROL	IMPLEMENTATION
Password / PIN hashing	PBKDF2-SHA256, 100,000 iterations, per-user 16-byte salt, constant-time comparison. (<code>convex/authCrypto.ts</code>)
Legacy hash migration	Legacy SHA-256 rows (no per-user salt) are detected on login and rehashed transparently to the modern format.
Rate-limiting tables	Per-phone (password), per-store (staff PIN, trial-room codes, kiosk pairing codes). Rolling-window counters.
Kiosk device auth	32-byte (256-bit) crypto-random bearer token, validated on every kiosk request; revocation supported (<code>devices.revokedAt</code>).
Cross-store isolation	Try-on actions verify <code>saree.storeId === session.storeId</code> ; look mutations verify <code>look.storeId === device.storeId</code> .
File-upload validation	Both client (<code>lib/uploadGuards.ts</code>) and server (<code>convex/fileValidation.ts</code>) enforce per-purpose size + MIME caps (e.g. body scan $\leq$ 10 MB, image/*; KYC doc $\leq$ 10 MB, image/* or PDF).
PII narrowing on public surfaces	The kiosk trial-room <code>validateCode</code> query deliberately returns a narrowed customer projection — no file IDs leaked, only a boolean <code>hasBodyScanFile</code> .
Secrets handling	RunPod, SendGrid, Twilio credentials live in Convex env vars; never reach the browser bundle.
Encryption at rest	Relies on Convex platform-level encryption (no application-layer envelope encryption).
Encryption in transit	All external HTTP calls are HTTPS to <code>https://</code> endpoints.

OVERALL

The security posture for authentication and access control is solid for a pre-launch product. The main weaknesses are not in *what* is implemented but in adjacent areas: retention, deletion, audit logging and consent UX (covered in their own sections).

11 Data Retention & Deletion — DPDP §8(7) & §12

DPDP §8(7) requires a Data Fiduciary to erase personal data when the purpose for which it was collected is no longer served. §12 provides the data principal the Right to Erasure on request. Wearify's current code does not implement either.

ITEM	CURRENT STATE
Retention policies (data)	The <code>retentionPolicies</code> table is defined in <code>convex/schema.ts</code> but no code reads or enforces it . There is no scheduled job that purges data based on category.
"Delete my account" — customer	Not implemented. No mutation exists. There is no UI option in <code>/c/me</code> to request account deletion.
Cascading delete	Even if a customer row is deleted manually, the dependent rows in <code>looks</code> , <code>wardrobe</code> , <code>visitHistory</code> , <code>loyaltyTransactions</code> , <code>customerStoreLinks</code> , <code>orders</code> , <code>tailorOrders</code> and others would be orphaned, not removed.
File-blob purge	Storing a new body scan replaces <code>customers.bodyScanFileId</code> but does not delete the underlying storage blob. Orphaned cutout PNGs <i>are</i> cleaned up after a failed mutation (see <code>tryOn.deleteOrphanCutout</code>) but no general blob garbage collector exists.
Session / OTP / token cleanup	Trial-room codes have a 15-minute TTL but expired rows are not purged. <code>userSessions</code> have expiry timestamps but no janitor.
Body-scan staleness	Cache invalidation works on re-scan (Section 15.4), but the platform does not <i>require</i> re-scan or auto-delete old scans after any retention period.

HIGHEST-PRIORITY ACTION

Before launch, implement (1) a customer-initiated account deletion flow, with cascading removal across all 19 PII-bearing tables and storage-blob cleanup, (2) per-category retention windows backed by the existing `retentionPolicies` table and a scheduled purge job, and (3) explicit auto-purge of body-scan blobs after a defined period (e.g. 6 or 12 months).

12 Audit Logging

The `auditLog` table is defined with the right shape (*timestamp, action, user, category, details*) and an `addAuditEntry` mutation exists at `convex/settings.ts:73-90`. However, a grep of the codebase shows **no call site invokes it**. The audit-logging infrastructure is present but is not instrumented.

COMPLIANCE GAP

DPDP §10 obliges Significant Data Fiduciaries to maintain records of processing activities. Even outside SDF status, a working audit trail is necessary to respond to a data principal's right to information (§11) and to support breach investigation (§8(6)). At minimum, the following should be logged: customer login, profile updates, consent changes, body-scan uploads, AI try-on initiation, admin data access, KYC document uploads, tailor referral creation, and campaign sends.

Although the main DPDP exposure concerns customer data, the platform also handles sensitive business / personal data for store owners and tailor partners. Counsel should be aware of these for completeness.

► **Store owners (collected via admin onboarding wizard)**

- Owner name, phone, email; GSTIN, PAN, shop-license number
- Bank account, IFSC, bank name
- File uploads: Aadhaar, PAN card, GST certificate, shop license, exterior & interior photos
- Signed agreements (MSA, DPA, AUP, hardware terms, SLA) with signer name and date

► **Tailor partners (collected via tailor self-registration + admin verification)**

- Name, phone, city, services, working hours
- File uploads: Aadhaar, PAN, address proof
- Verification flags + admin rejection note (`kycRejectionReason`)
- DPDP-style consent flags (`consentProfile` , `consentLocation` , `consentAnalytics`)

The same retention and deletion gaps identified for customer data apply equally to store and tailor KYC files.

14 Identified Compliance Gaps

Summary table of all material gaps identified above, with risk rating and the corresponding DPDP provision.

GAP	RISK	DPDP REF.	RECOMMENDED ACTION
No customer account-deletion flow	HIGH	§12 (right to erasure)	Build a "delete my account" mutation with cascading delete across all PII tables and storage blobs; expose in <code>/c/me</code> .
Consent default-TRUE on customer creation	HIGH	§6 (clear affirmative action)	Remove the default-true on <code>ensureCustomerByPhone</code> ; require the consent screen to be the only place flags are set.
Age gate is 13+, not 18+; no parental consent	HIGH	§9 (children)	Either raise gate to 18, or implement a verifiable-parental-consent flow for 13-17 customers. Suppress behavioural profiling and marketing for under-18s.
Bundled consent (4 flags under one "Allow")	MED	§6 (specific)	Split into per-purpose toggles, or at minimum split "photos / AI personalisation" from "marketing messages".
No consent-withdrawal UI	HIGH	§6(4)–(6)	Add a consent-management screen in <code>/c/me</code> showing current flags with toggles to withdraw.
No retention windows enforced	HIGH	§8(7)	Define retention policy per data category; write a scheduled purge that consumes the <code>retentionPolicies</code> table.
Body-scan images stored indefinitely	HIGH	§8(7), purpose-limitation	Auto-delete body-scan blobs after a defined window (e.g. 6 or 12 months) or on consent withdrawal.
Audit log defined but never written	MED	§10, §11	Instrument all PII-touching mutations to call <code>settings.addAuditEntry</code> .
Cross-border data flows without visible DPAs	HIGH	§8(8), §16	Verify executed DPAs with Convex, RunPod, SendGrid, Twilio. Disclose transfers in the privacy notice.
Privacy notice / legal docs not surfaced	HIGH	§5 (notice)	Populate <code>legalDocs</code> ; build admin upload UI and customer-facing view; version-stamp every consent record.
Server-side age check missing on <code>ensureByPhone</code>	MED	§9	Add age validation to the Convex mutation, not only the UI.
Tailor sharing — no explicit consent step	MED	§6	Add a "share with tailor" consent capture at the referral / order-creation step, or rely on a clearly-disclosed contractual-necessity basis.
Campaign recipient stored in plaintext in <code>campaignSends</code>	LOW	§8(5) (security)	Acceptable for dispatch logs; ensure retention window is short and admin access is audited.
No appointed Data Protection Officer / contact	MED	§10(2)(a)	Counsel to advise on whether Wearify qualifies as a Significant Data Fiduciary; appoint a DPO and publish a complaint-channel contact.

15 Patent-Relevant Novel Aspects

Five technical areas identified in the codebase warrant patent-counsel review. None is individually a "blockbuster" claim, but together they describe a defensible family covering virtual try-on in retail kiosks plus IoT device pairing in multi-store environments.

► 15.1 AI try-on pipeline — Qwen-Image-Edit + saree LoRA + flat-lay garment selection

A ComfyUI pipeline combining Qwen-Image-Edit 2511 as the diffusion base, a custom *Object-Adder* LoRA tuned for saree replacement, and a non-obvious garment-image selection rule (*imageIds[3] → [2] → [0]*) that prefers flat-lay catalog photos over model-wearing shots. The flat-lay selection materially suppresses "model-face leak" in the rendered output. Sourcing: `convex/runpod.ts` (workflow + LoRA config), `convex/tryOn.ts:552-557` (garment selection chain).

► 15.2 Kiosk pairing protocol — ephemeral codes + persistent device tokens with per-store rate-limiting

A two-tier identity scheme: a low-entropy, 2-minute-TTL, human-typeable 6-digit code issued by an authorised principal (admin or store owner) is consumed once by a fresh kiosk to mint a 32-byte (256-bit) opaque bearer token. Brute-force enumeration of the code space is prevented by a per-store rolling-window failure counter. The protocol uses no PKI / certificates. Sourcing: `convex/kioskPairing.ts`, `convex/kioskAuth.ts`.

► 15.3 Trial-room access-code handoff between tablet and mirror

A 6-digit single-use code with 15-minute TTL is generated on a sales tablet, handed to the customer, and consumed at a kiosk mirror to load the staff-curated saree shortlist into the customer's session. The code mediates a device-to-device session handoff without Bluetooth, NFC, or pre-registration of the two devices to each other. Sourcing:

`convex/trialRoom.ts`, `convex/schema.ts:395-419`.

► 15.4 Body-scan cache invalidation by file-identity, not timestamp

Completed AI renders are reused across sessions for the same (customer, saree) pair *only when* the `Looks.personFileId` snapshot still equals the customer's current `bodyScanFileId`. A re-scan changes the file identity and automatically invalidates every prior render, with no clocks, no TTL configuration, and no admin intervention. This is a subtle but real distributed-systems primitive applied to a retail-personalisation problem. Sourcing: `convex/tryOn.ts:1052-1084` (`getCachedLooksForSarees`).

► 15.5 Sequential WASM background-removal queue for resource-bounded edge devices

A module-singleton FIFO queue runs *one* @imgly/background-removal job at a time on the kiosk browser, holding the ~200 MB WASM model warm in memory. A parallel implementation would replicate the model per job, exceeding tablet memory limits; the sequential choice trades wall-clock for bounded RAM and preserves UI responsiveness with explicit queue-position feedback. Sourcing: `lib/bgRemovalQueue.ts`, with rationale in `CONTEXT.md`.

FOR PATENT COUNSEL

All five are eligible for novelty and non-obviousness analysis. Counsel may further consider claiming the *combination* — a retail platform whose smart-mirror device is paired via an ephemeral code, hands customer sessions from a separate tablet via a second ephemeral code, runs personalised AI garment-replacement on a GPU with a fabric-specific LoRA, and caches results by file-identity — as a single system claim covering the integrated invention.

16 Questions for Counsel

1. **SDF status:** Given biometric-adjacent body-scan data, multi-store customer profiles and AI behavioural personalisation, is Wearify likely to be designated a Significant Data Fiduciary under DPDP §10? If so, what are the immediate obligations (DPO appointment, DPIA, audit, child-data restrictions)?
2. **Children:** Should the age gate be raised to 18 immediately, or is a verifiable-parental-consent flow for 13–17 customers acceptable? What "verifiable" mechanism does counsel accept (parent OTP, government ID, signed declaration)?
3. **Consent UX:** Will counsel accept a single "I agree" with a layered privacy notice, or are per-purpose checkboxes required to satisfy the "specific" prong of §6?
4. **Cross-border transfers:** Are the existing service contracts with Convex, RunPod, SendGrid and Twilio sufficient under §8(8) / §16, or are Standard Contractual Clauses (or India-specific equivalents) required? Should launch wait for the planned Azure-Central-India migration?
5. **Body-scan retention:** What is an appropriate maximum retention period for a customer's body-scan photograph? Should it auto-delete on each re-scan (keeping only the latest), on consent withdrawal, on account deletion, after a fixed window, or some combination?
6. **Tailor sharing:** Is sharing customer name, phone and measurements with the tailor partner adequately covered by contractual necessity (the customer is ordering a blouse from that tailor), or is an explicit "share with tailor" consent step required?
7. **Privacy notice / terms:** Should the privacy notice and terms be drafted by counsel before launch? If so, how should we surface them in-product so they are version-stamped against each consent record?
8. **Data-breach response:** Counsel to advise on the §8(6) breach notification process and on assembling a tabletop breach-response plan before launch.
9. **Patent strategy:** Patent counsel to assess novelty and non-obviousness of each item in Section 15 and recommend filing strategy (single consolidated application vs. divisional family; PCT timing; India-only vs. international).
10. **Trademarks & brand:** Confirm Wearify brand registration status and any conflicts on "Wearify" / saree-try-on category.

APPENDIX AVAILABLE ON REQUEST

Source-level evidence for every finding in this brief (file paths, line numbers and excerpts) is on file and can be made available to counsel for diligence. The accompanying System Architecture Review document contains the full technical description of the platform and may serve as the technical exhibit for the patent filing.